

Plan de Continuidad de Negocio (BCP)

Escenario

Los sistemas críticos como el CRM, Repositorios Git y/o Plataformas de servicio en la nube dejan de funcionar generando una interrupción prolongada.

Objetivo

Mantener la operatividad del desarrollo de software y el soporte técnico que se brinda para nuestros clientes sin interrupciones graves.

Alcance

Este plan contempla la continuidad operativa del desarrollo de sistemas, soporte técnico mediante los sistemas CRM y procesos administrativos importantes como la facturación y pagos.

Proceso crítico

Gestión de repositorios de código, plataforma de servicio en la nube y atención a solicitudes de soporte técnico.

Tiempo máximo tolerable

4 horas

Estrategias de continuidad:

1. Canales alternos de soporte: Se debe de usar el correo empresarial y crear/almacenar tickets en Microsoft Excel si el CRM falla.
2. Registro manual de operaciones: De ser necesario se deben de registrar en papel o en Microsoft Word los datos sobre facturación y pagos.
3. Comunicación proactiva: Notificar a los clientes sobre el uso de medios alternos para soporte técnico.
4. Uso de entornos secundarios:
 - Crear/Activar ambientes de desarrollo secundarios distintos de AWS/Azure y/o
 - Crear/Activar repositorios locales para no detener la operatividad.

Roles definidos para cada área

Líder de incidente: Es el líder del CSIRT, se encarga de iniciar, supervisar y terminar cada etapa de este plan.

CSIRT: Es el equipo especializado encargado de detectar, analizar, responder y recuperar a la organización de incidentes de seguridad de la información.

Comité de seguridad: Coordina la acción inicial y las subsecuentes junto al líder del incidente, además de evaluar el cumplimiento de políticas.

Coordinador de desarrollo: Asegura la integridad del código fuente y activa los entornos secundarios de desarrollo.

Coordinador de comunicación: Informa al equipo de negocio y a los clientes sobre el estado del incidente.

Acciones durante el incidente

0-15 min: El CSIRT detecta la caída de un servicio crítico (el CRM, los repositorios de Git o las plataformas de servicio en la nube) y notifica al Comité de Seguridad de la Información. El líder del incidente declara formalmente el BCP activo.

15-30 min: El área de Atención a Clientes publica un aviso en canales oficiales informando sobre la interrupción y los medios alternos de comunicación. El equipo de Desarrollo de Software activa el acceso a los repositorios locales o a los entornos secundarios para no detener la producción.

30min-2hrs: Los desarrolladores trabajan en entornos de desarrollo alternos mientras se detecta el origen de la falla principal. El área administrativa inicia el registro manual de los datos para facturación o pagos, usando papel o la herramienta Microsoft Word.

Atención a clientes administra las solicitudes técnicas exclusivamente por correo empresarial y haciendo uso de Microsoft Excel.

2-4hrs: El CSIRT realiza tareas de restauración técnica según en DRP.

Restauración: Una vez que la plataforma vuelva a estar operativa, el líder del incidente valida que los sistemas están íntegros.

Sincronización: Toda la información registrada manualmente durante la crisis se ingresa formalmente a los sistemas principales.

Después del incidente: Se notifica a los clientes sobre la normalización del servicio. El Comité de Seguridad de la Información junto con el CSIRT documenta el incidente, analiza el origen del incidente y actualiza el plan siguiendo el ciclo de mejora continua (ciclo PDCA).

Capacitación y concientización

Programa de sensibilización: Se realizarán sesiones semestrales para todo el personal sobre el uso de canales alternos (correo empresarial y registros manuales).

Difusión de Roles: Cada líder de área debe asegurar que su equipo conozca que persona ejerce cada rol descrito en este plan y cuáles son sus responsabilidades durante una crisis.

Inducción: Todo nuevo empleado recibirá una breve capacitación sobre el “Plan de Continuidad de Negocio” de NovaTech.

Plan de Recuperación de Desastres (DRP)

Escenario

Caída total de los sistemas críticos por ataque informático (Ransomware, DDoS, etc), falla crítica de las plataformas de servicio en la nube o pérdida masiva de datos (borrado accidental o corrupción de la información).

Objetivo

Restaurar y mantener la integridad de los servicios digitales, las bases de datos de clientes y el código fuente en el menor tiempo posible.

Alcance

Este plan contempla la restauración y recuperación de los siguientes servicios tecnológicos críticos:

- Infraestructura de servidores: Incluyen todos los servidores en la nube (AWS/Azure) que contienen las plataformas web y los ecosistemas digitales de los clientes, así como los servidores locales.
- Código fuente: Cubre la recuperación de los repositorios Git y los servidores que contengan propiedad intelectual valiosa para la empresa.
- Bases de datos: Incluye las bases de datos de clientes (CRM), información financiera como la facturación y los pagos y datos personales de los empleados.

Sistemas críticos

- Plataforma CRM y bases de datos.
- Servicios de la nube (AWS/Azure).
- Repositorios que contengan el código fuente (Git).

Parámetros de recuperación

RTO (Recovery Time Objective) - 4 horas

Tiempo máximo permitido para que los sistemas vuelvan a estar operativos. Si se supera, las pérdidas económicas y de reputación se vuelven críticas.

RPO (Recovery Point Objective) - 24 horas

Máxima cantidad de datos que se puede aceptar perder. Significa que los respaldos deben realizarse al menos cada día para cumplir este objetivo.

Roles definidos para cada área

Líder del CSIRT: Será el líder del DRP, dirige la restauración y decide el momento de la restauración.

Administrador de TI: Ejecuta la recuperación y validación de datos.

Coordinador de infraestructura: Configura las redes, firewalls y servidor secundario.

Coordinador de Comunicación: Informa al equipo de negocio y a los clientes sobre el estado del incidente.

Dirección: Autoriza recursos adicionales si la recuperación lo requiere y aprueba el cierre del incidente.

Procedimientos técnicos definidos

1. Detección y alerta (0 – 15min)

El CSIRT detecta una anomalía como la caída del CRM, inaccesibilidad a Git o tráfico extraño por ataque informático, alertando automáticamente al equipo de TI.

El líder del CSIRT verifica la gravedad del hecho y activa el plan de recuperación de desastres, así mismo, notifica al coordinador de comunicación para que informe al equipo.

2. Evaluación del daño (15 – 45min)

El CSIRT determina si el origen de la falla es del proveedor, un error humano, un ataque de ransomware, DDoS u otro y se identifican los activos afectados: bases de datos, código fuente o servicios web, para después analizar el impacto a la empresa.

Se busca el respaldo más reciente y completo.

3. Aislamiento y aseguramiento (Si es ataque informático)

Se desconectan los dispositivos comprometidos de la red principal para evitar la propagación del ataque.

4. Activación de servicios alternos (45min – 2hrs)

El coordinador de infraestructura activará el servidor secundario distinto a la nube (AWS/Azure) y configurará la red, firewalls y certificados de seguridad. Carga el respaldo seleccionado al servidor secundario y verifica la consistencia de los datos.

5. Restauración de datos y código fuente (2hrs – 3hrs)

El administrador de TI junto al CSIRT ayudan a restaurar la versión principal de los repositorios Git tomando como base la del servidor secundario una vez que se haya analizado si no hubo modificaciones maliciosas. Realizaran un

escaneo de vulnerabilidades previo a la reconexión para estar seguros de que no hay rastros de malware.

6. Pruebas y reconexión (3hrs – 4hrs)

El administrador de TI junto al CSIRT realizarán pruebas de conectividad con el CRM, las bases de datos y las aplicaciones web.

7. Cierre del incidente

Después de la restauración, el CSIRT documenta la causa raíz y el tiempo real de la recuperación para generar un reporte usando estas métricas. Toda la información que se generó manualmente durante el BCP se integra a los sistemas ya recuperados para mantener la integridad de la información. La Dirección oficialmente cierra el incidente.

Infraestructura alterna disponible

Componente	Principal	Alternativo
Repositorios de Código	Servidor Git Principal	Servidor secundario
Soporte técnico	CRM	Comunicación por correo electrónico
Servicios Web	Servicios en la nube como AWS/Azure	Servidor secundario

Plan de simulacros técnicos

Se llevará a cabo un simulacro técnico anual.

Tipos de pruebas:

- Pruebas de escritorio: Revisión técnica de los pasos de recuperación con el equipo de TI, desarrollo y el Comité de Seguridad.
- Simulacro de restauración (entorno controlado): Recuperación real de una base de datos y el código fuente en el servidor secundario para medir el RTO real.

Informe de resultados: Después cada simulacro, se compartirá un reporte detallando sobre si se cumplió la meta de 4 horas y qué ajustes necesita el plan.